

Security Analysis Report

Project:	2026SE_MajorProject_Kelvin.A
Generated:	2026-06-19 13:02:37
Scope:	SAST, Dependency Audit, Network Check, Penetration Testing

1. SAST - Bandit Static Analysis

```
Working... ????????????????????????????????????????????????????????? 100% 0:01:17
Run started:2026-06-19 13:02:30.633244+00:00
```

Test results:

```
>> Issue: [B613:trojansource] A Python source file contains bidirectional control characters ('\u202e').
Severity: High    Confidence: Medium
CWE: CWE-838 (https://cwe.mitre.org/data/definitions/838.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b613\_trojansource.html
Location: ../.venv/lib/python3.12/site-packages/bandit/plugins/trojansource.py:22:36
```

```
21     3     access_level = "user"
22     4         if access_level != 'none??: # Check if admin ??' and access_level != 'user
23     5             print("You are an admin.\n")
```

```
>> Issue: [B411:blacklist] Using xmlrpc to parse untrusted XML data is known to be vulnerable to XML attacks.
Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML vulnerabilities.
```

Severity: High Confidence: High
CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib
Location: `./venv/lib/python3.12/site-packages/defusedxml/__init__.py:37:4`

```
36     from . import expatreader
37     from . import xmlrpc
38
```

```
>> Issue: [B319:blacklist] Using xml.dom.pulldom.parse to parse untrusted XML data is known to be vulnerable to XML attacks. Replace xml.dom.pulldom.parse with its defusedxml equivalent function or make sure defusedxml.defuse_stdlib() is called
```

Severity: Medium Confidence: High
CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b313-b320-xml-bad-pulldom
Location: `./venv/lib/python3.12/site-packages/defusedxml/pulldom.py:30:11`

```

29     parser.forbid_external = forbid_external
30     return _parse(stream_or_string, parser, bufsize)
31

```

```
>> Issue: [B319:blacklist] Using xml.dom.pulldom.parseString to parse untrusted XML data is known to be
vulnerable to XML attacks. Replace xml.dom.pulldom.parseString with its defusedxml equivalent function or make
sure defusedxml.defuse_stdlib() is called
```

Severity: Medium Confidence: High
CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b313-b320-xml-bad-pulldom
Location: `./venv/lib/python3.12/site-packages/defusedxml/pulldom.py:41:11`

```

40     parser.forbid_external = forbid_external
41     return _parseString(string, parser)

```

```
>> Issue: [B411:blacklist] Using ExpatParser to parse untrusted XML data is known to be vulnerable to XML
```

Security Analysis Report

attacks. Use `defusedxml.xmlrpc.monkey_patch()` function to monkey-patch `xmlrpclib` and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./.venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:18:4`

```
17     __origin__ = "xmlrpc.client"
18     from xmlrpc.client import ExpatParser
19     from xmlrpc import client as xmlrpc_client
```

>> Issue: [B411:blacklist] Using client to parse untrusted XML data is known to be vulnerable to XML attacks. Use `defusedxml.xmlrpc.monkey_patch()` function to monkey-patch `xmlrpclib` and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./.venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:19:4`

```
18     from xmlrpc.client import ExpatParser
19     from xmlrpc import client as xmlrpc_client
20     from xmlrpc import server as xmlrpc_server
```

>> Issue: [B411:blacklist] Using server to parse untrusted XML data is known to be vulnerable to XML attacks. Use `defusedxml.xmlrpc.monkey_patch()` function to monkey-patch `xmlrpclib` and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./.venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:20:4`

```
19     from xmlrpc import client as xmlrpc_client
20     from xmlrpc import server as xmlrpc_server
21     from xmlrpc.client import gzip_decode as _orig_gzip_decode
```

>> Issue: [B411:blacklist] Using `gzip_decode` to parse untrusted XML data is known to be vulnerable to XML attacks. Use `defusedxml.xmlrpc.monkey_patch()` function to monkey-patch `xmlrpclib` and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./.venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:21:4`

```
20     from xmlrpc import server as xmlrpc_server
21     from xmlrpc.client import gzip_decode as _orig_gzip_decode
22     from xmlrpc.client import GzipDecodedResponse as _OrigGzipDecodedResponse
```

>> Issue: [B411:blacklist] Using `GzipDecodedResponse` to parse untrusted XML data is known to be vulnerable to XML attacks. Use `defusedxml.xmlrpc.monkey_patch()` function to monkey-patch `xmlrpclib` and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./.venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:22:4`

```
21     from xmlrpc.client import gzip_decode as _orig_gzip_decode
22     from xmlrpc.client import GzipDecodedResponse as _OrigGzipDecodedResponse
23 else:
```

Security Analysis Report

>> Issue: [B411:blacklist] Using ExpatParser to parse untrusted XML data is known to be vulnerable to XML attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: ../venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:25:4

```
24     __origin__ = "xmlrpclib"
25     from xmlrpclib import ExpatParser
26     import xmlrpclib as xmlrpc_client
```

>> Issue: [B411:blacklist] Using xmlrpclib to parse untrusted XML data is known to be vulnerable to XML attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: ../venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:26:4

```
25     from xmlrpclib import ExpatParser
26     import xmlrpclib as xmlrpc_client
27
```

>> Issue: [B411:blacklist] Using gzip_decode to parse untrusted XML data is known to be vulnerable to XML attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: ../venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:29:4

```
28     xmlrpc_server = None
29     from xmlrpclib import gzip_decode as _orig_gzip_decode
30     from xmlrpclib import GzipDecodedResponse as _OrigGzipDecodedResponse
```

>> Issue: [B411:blacklist] Using GzipDecodedResponse to parse untrusted XML data is known to be vulnerable to XML attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: ../venv/lib/python3.12/site-packages/defusedxml/xmlrpc.py:30:4

```
29     from xmlrpclib import gzip_decode as _orig_gzip_decode
30     from xmlrpclib import GzipDecodedResponse as _OrigGzipDecodedResponse
31
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: ../venv/lib/python3.12/site-packages/fontTools/misc/symfont.py:241:24

```
240     penName = sys.argv[1]
241     funcs = [(name, eval(f)) for name, f in zip(sys.argv[2::2], sys.argv[3::2])]
242     printGreenPen(penName, funcs, file=sys.stdout)
```

Security Analysis Report

>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.

Severity: Medium Confidence: Low

CWE: CWE-89 (<https://cwe.mitre.org/data/definitions/89.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html

Location: ./venv/lib/python3.12/site-packages/fontTools/subset/__init__.py:33:4

```
32 __doc__ = (  
33     """\n  
34 fonttools subset -- OpenType font subsetter and optimizer  
35  
36 fonttools subset is an OpenType font subsetter and optimizer, based on  
37 fontTools. It accepts any TT- or CFF-flavored OpenType (.otf or .ttf)  
38 or WOFF (.woff) font file. The subsetted glyph set is based on the  
39 specified glyphs or characters, and specified OpenType layout features.  
40  
41 The tool also performs some size-reducing optimizations, aimed for using  
42 subset fonts as webfonts. Individual optimizations can be enabled or  
43 disabled, and are enabled by default when they are safe.  
44  
45 Usage: """  
46     + __usage__  
47     + """
```

>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.

Severity: Medium Confidence: Low

CWE: CWE-89 (<https://cwe.mitre.org/data/definitions/89.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html

Location: ./venv/lib/python3.12/site-packages/fontTools/subset/__init__.py:47:6

```
46     + __usage__  
47     + """  
48  
49 At least one glyph or one of --gids, --gids-file, --glyphs, --glyphs-file,  
50 --text, --text-file, --unicodes, or --unicodes-file, must be specified.  
51  
52 Args:  
53  
54 font-file  
55     The input font file.  
56 glyph  
57     Specify one or more glyph identifiers to include in the subset. Must be  
58     PS glyph names, or the special string '*' to keep the entire glyph set.  
59  
60 Initial glyph set specification  
61 ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
62  
63 These options populate the initial glyph set. Same option can appear  
64 multiple times, and the results are accumulated.  
65  
66 --gids=<NNN>[,<NNN>...]  
67     Specify comma/whitespace-separated list of glyph IDs or ranges as decimal  
68     numbers. For example, --gids=10-12,14 adds glyphs with numbers 10, 11,  
69     12, and 14.  
70  
71 --gids-file=<path>
```

Security Analysis Report

```
72 Like --gids but reads from a file. Anything after a '#' on any line is
73 ignored as comments.
74
75 --glyphs=<glyphname>[,<glyphname>...]
76 Specify comma/whitespace-separated PS glyph names to add to the subset.
77 Note that only PS glyph names are accepted, not gidNNN, U+XXXX, etc
78 that are accepted on the command line. The special string '*' will keep
79 the entire glyph set.
80
81 --glyphs-file=<path>
82 Like --glyphs but reads from a file. Anything after a '#' on any line
83 is ignored as comments.
84
85 --text=<text>
86 Specify characters to include in the subset, as UTF-8 string.
87
88 --text-file=<path>
89 Like --text but reads from a file. Newline character are not added to
90 the subset.
91
92 --unicodes=<XXXX>[,<XXXX>...]
93 Specify comma/whitespace-separated list of Unicode codepoints or
94 ranges as hex numbers, optionally prefixed with 'U+', 'u', etc.
95 For example, --unicodes=41-5a,61-7a adds ASCII letters, so does
96 the more verbose --unicodes=U+0041-005A,U+0061-007A.
97 The special strings '*' will choose all Unicode characters mapped
98 by the font.
99
100 --unicodes-file=<path>
101 Like --unicodes, but reads from a file. Anything after a '#' on any
102 line in the file is ignored as comments.
103
104 --ignore-missing-glyphs
105 Do not fail if some requested glyphs or gids are not available in
106 the font.
107
108 --no-ignore-missing-glyphs
109 Stop and fail if some requested glyphs or gids are not available
110 in the font. [default]
111
112 --ignore-missing-unicodes [default]
113 Do not fail if some requested Unicode characters (including those
114 indirectly specified using --text or --text-file) are not available
115 in the font.
116
117 --no-ignore-missing-unicodes
118 Stop and fail if some requested Unicode characters are not available
119 in the font.
120 Note the default discrepancy between ignoring missing glyphs versus
121 unicodes. This is for historical reasons and in the future
122 --no-ignore-missing-unicodes might become default.
123
124 Other options
125 ^^^^^^^^^^^^^^^
126
127 For the other options listed below, to see the current value of the option,
128 pass a value of '?' to it, with or without a '='. In some environments,
```

Security Analysis Report

```
129 you might need to escape the question mark, like this: '--glyph-names\\?'.
130
131 Examples::
132
133     $ fonttools subset --glyph-names?
134     Current setting for 'glyph-names' is: False
135     $ fonttools subset --name-IDs=?
136     Current setting for 'name-IDs' is: [0, 1, 2, 3, 4, 5, 6]
137     $ fonttools subset --hinting? --no-hinting --hinting?
138     Current setting for 'hinting' is: True
139     Current setting for 'hinting' is: False
140
141 Output options
142 ^^^^^^^^^^^^^^^^^
143
144 --output-file=<path>
145     The output font file. If not specified, the subsetted font
146     will be saved in as font-file.subset.
147
148 --flavor=<type>
149     Specify flavor of output font file. May be 'woff' or 'woff2'.
150     Note that WOFF2 requires the Brotli Python extension, available
151     at https://github.com/google/brotli
152
153 --with-zopfli
154     Use the Google Zopfli algorithm to compress WOFF. The output is 3-8 %
155     smaller than pure zlib, but the compression speed is much slower.
156     The Zopfli Python bindings are available at:
157     https://pypi.python.org/pypi/zopfli
158
159 --harfbuzz-repacker
160     By default, we serialize GPOS/GSUB using the HarfBuzz Repacker when
161     uharfbuzz can be imported and is successful, otherwise fall back to
162     the pure-python serializer. Set the option to force using the HarfBuzz
163     Repacker (raises an error if uharfbuzz can't be found or fails).
164
165 --no-harfbuzz-repacker
166     Always use the pure-python serializer even if uharfbuzz is available.
167
168 Glyph set expansion
169 ^^^^^^^^^^^^^^^^^
170
171 These options control how additional glyphs are added to the subset.
172
173 --retain-gids
174     Retain glyph indices; just empty glyphs not needed in-place.
175
176 --notdef-glyph
177     Add the '.notdef' glyph to the subset (ie, keep it). [default]
178
179 --no-notdef-glyph
180     Drop the '.notdef' glyph unless specified in the glyph set. This
181     saves a few bytes, but is not possible for Postscript-flavored
182     fonts, as those require '.notdef'. For TrueType-flavored fonts,
183     this works fine as long as no unsupported glyphs are requested
184     from the font.
185
```

Security Analysis Report

```
186 --notdef-outline
187     Keep the outline of '.notdef' glyph. The '.notdef' glyph outline is
188     used when glyphs not supported by the font are to be shown. It is not
189     needed otherwise.
190
191 --no-notdef-outline
192     When including a '.notdef' glyph, remove its outline. This saves
193     a few bytes. [default]
194
195 --recommended-glyphs
196     Add glyphs 0, 1, 2, and 3 to the subset, as recommended for
197     TrueType-flavored fonts: '.notdef', 'NULL' or '.null', 'CR', 'space'.
198     Some legacy software might require this, but no modern system does.
199
200 --no-recommended-glyphs
201     Do not add glyphs 0, 1, 2, and 3 to the subset, unless specified in
202     glyph set. [default]
203
204 --no-layout-closure
205     Do not expand glyph set to add glyphs produced by OpenType layout
206     features. Instead, OpenType layout features will be subset to only
207     rules that are relevant to the otherwise-specified glyph set.
208
209 --layout-features[+|-]=<feature>[,<feature>...]
210     Specify (=), add to (+) or exclude from (-) the comma-separated
211     set of OpenType layout feature tags that will be preserved.
212     Glyph variants used by the preserved features are added to the
213     specified subset glyph set. By default, 'calt', 'ccmp', 'clig', 'curs',
214     'dnom', 'frac', 'kern', 'liga', 'locl', 'mark', 'mkmk', 'numr', 'rclt',
215     'rlig', 'rvrn', and all features required for script shaping are
216     preserved. To see the full list, try '--layout-features=?'.
217     Use '*' to keep all features.
218     Multiple --layout-features options can be provided if necessary.
219     Examples:
220
221     --layout-features+=onum,pnum,ss01
222         * Keep the default set of features and 'onum', 'pnum', 'ss01'.
223     --layout-features-='mark','mkmk'
224         * Keep the default set of features but drop 'mark' and 'mkmk'.
225     --layout-features='kern'
226         * Only keep the 'kern' feature, drop all others.
227     --layout-features=''
228         * Drop all features.
229     --layout-features='*'
230         * Keep all features.
231     --layout-features+=aalt --layout-features-=vrt2
232         * Keep default set of features plus 'aalt', but drop 'vrt2'.
233
234 --layout-scripts[+|-]=<script>[,<script>...]
235     Specify (=), add to (+) or exclude from (-) the comma-separated
236     set of OpenType layout script tags that will be preserved. LangSys tags
237     can be appended to script tag, separated by '.', for example:
238     'arab.dflt,arab.URD,latn.TRK'. By default all scripts are retained ('*').
239
240 Hinting options
241 ^^^^^^^^^^^^^^^^^^
242
```

Security Analysis Report

```
243 --hinting
244     Keep hinting [default]
245
246 --no-hinting
247     Drop glyph-specific hinting and font-wide hinting tables, as well
248     as remove hinting-related bits and pieces from other tables (eg. GPOS).
249     See --hinting-tables for list of tables that are dropped by default.
250     Instructions and hints are stripped from 'glyf' and 'CFF ' tables
251     respectively. This produces (sometimes up to 30%) smaller fonts that
252     are suitable for extremely high-resolution systems, like high-end
253     mobile devices and retina displays.
254
255 Optimization options
256 ^^^^^^^^^^^^^^^^^^^^^^^^^
257
258 --desubroutinize
259     Remove CFF use of subroutinizes. Subroutinization is a way to make CFF
260     fonts smaller. For small subsets however, desubroutinizing might make
261     the font smaller. It has even been reported that desubroutinized CFF
262     fonts compress better (produce smaller output) WOFF and WOFF2 fonts.
263     Also see note under --no-hinting.
264
265 --no-desubroutinize [default]
266     Leave CFF subroutinizes as is, only throw away unused subroutinizes.
267
268 Font table options
269 ^^^^^^^^^^^^^^^^^^^^^^^^^
270
271 --drop-tables[+|-]=<table>[,<table>...]
272     Specify (=), add to (+) or exclude from (-) the comma-separated
273     set of tables that will be dropped.
274     By default, the following tables are dropped:
275     'JSTF', 'DSIG', 'EBDT', 'EBLC', 'EBSC', 'PCLT', 'LTSH'
276     and Graphite tables: 'Feat', 'Glat', 'Gloc', 'Silf', 'Sill'.
277     The tool will attempt to subset the remaining tables.
278
279 Examples:
280
281 --drop-tables-=BASE
282     * Drop the default set of tables but keep 'BASE'.
283
284 --drop-tables+=GSUB
285     * Drop the default set of tables and 'GSUB'.
286
287 --drop-tables=DSIG
288     * Only drop the 'DSIG' table, keep all others.
289
290 --drop-tables=
291     * Keep all tables.
292
293 --no-subset-tables+=<table>[,<table>...]
294     Add to the set of tables that will not be subsetted.
295     By default, the following tables are included in this list, as
296     they do not need subsetting (ignore the fact that 'loca' is listed
297     here): 'gasp', 'head', 'hhea', 'maxp', 'vhea', 'OS/2', 'loca', 'name',
298     'cvt ', 'fpgm', 'prep', 'VMDX', 'DSIG', 'CPAL', 'MVAR', 'cvar', 'STAT'.
299     By default, tables that the tool does not know how to subset and are not
```


Security Analysis Report

```
300 specified here will be dropped from the font, unless --passthrough-tables
301 option is passed.
302
303 Example:
304
305     --no-subset-tables+=FFTM
306         * Keep 'FFTM' table in the font by preventing subsetting.
307
308 --passthrough-tables
309 Do not drop tables that the tool does not know how to subset.
310
311 --no-passthrough-tables
312 Tables that the tool does not know how to subset and are not specified
313 in --no-subset-tables will be dropped from the font. [default]
314
315 --hinting-tables[-]=<table>[,<table>...]
316 Specify (=), add to (+=) or exclude from (-=) the list of font-wide
317 hinting tables that will be dropped if --no-hinting is specified.
318
319 Examples:
320
321 --hinting-tables-=VDMX
322     * Drop font-wide hinting tables except 'VDMX'.
323 --hinting-tables=
324     * Keep all font-wide hinting tables (but strip hints from glyphs).
325
326 --legacy-kern
327 Keep TrueType 'kern' table even when OpenType 'GPOS' is available.
328
329 --no-legacy-kern
330 Drop TrueType 'kern' table if OpenType 'GPOS' is available. [default]
331
332 Font naming options
333 ^^^^^^^^^^^^^^^^^^^^^^^^^
334
335 These options control what is retained in the 'name' table. For numerical
336 codes, see: http://www.microsoft.com/typography/otspec/name.htm
337
338 --name-IDs[+|-]=<nameID>[,<nameID>...]
339 Specify (=), add to (+=) or exclude from (-=) the set of 'name' table
340 entry nameIDs that will be preserved. By default, only nameIDs between 0
341 and 6 are preserved, the rest are dropped. Use '*' to keep all entries.
342
343 Examples:
344
345 --name-IDs+=7,8,9
346     * Also keep Trademark, Manufacturer and Designer name entries.
347 --name-IDs=
348     * Drop all 'name' table entries.
349 --name-IDs=*
350     * keep all 'name' table entries
351
352 --name-legacy
353 Keep legacy (non-Unicode) 'name' table entries (0.x, 1.x etc.).
354 XXX Note: This might be needed for some fonts that have no Unicode name
355 entires for English. See: https://github.com/fonttools/fonttools/issues/146
```

Security Analysis Report

```
357 --no-name-legacy
358   Drop legacy (non-Unicode) 'name' table entries [default]
359
360 --name-languages[+|-]=<langID>[,<langID>]
361   Specify (=), add to (+) or exclude from (-) the set of 'name' table
362   langIDs that will be preserved. By default only records with langID
363   0x0409 (English) are preserved. Use '*' to keep all langIDs.
364
365 --obfuscate-names
366   Make the font unusable as a system font by replacing name IDs 1, 2, 3, 4,
367   and 6 with dummy strings (it is still fully functional as webfont).
368
369 Glyph naming and encoding options
370 ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
371
372 --glyph-names
373   Keep PS glyph names in TT-flavored fonts. In general glyph names are
374   not needed for correct use of the font. However, some PDF generators
375   and PDF viewers might rely on glyph names to extract Unicode text
376   from PDF documents.
377 --no-glyph-names
378   Drop PS glyph names in TT-flavored fonts, by using 'post' table
379   version 3.0. [default]
380 --legacy-cmap
381   Keep the legacy 'cmap' subtables (0.x, 1.x, 4.x etc.).
382 --no-legacy-cmap
383   Drop the legacy 'cmap' subtables. [default]
384 --symbol-cmap
385   Keep the 3.0 symbol 'cmap'.
386 --no-symbol-cmap
387   Drop the 3.0 symbol 'cmap'. [default]
388
389 Other font-specific options
390 ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
391
392 --recalc-bounds
393   Recalculate font bounding boxes.
394 --no-recalc-bounds
395   Keep original font bounding boxes. This is faster and still safe
396   for all practical purposes. [default]
397 --recalc-timestamp
398   Set font 'modified' timestamp to current time.
399 --no-recalc-timestamp
400   Do not modify font 'modified' timestamp. [default]
401 --canonical-order
402   Order tables as recommended in the OpenType standard. This is not
403   required by the standard, nor by any known implementation.
404 --no-canonical-order
405   Keep original order of font tables. This is faster. [default]
406 --prune-unicode-ranges
407   Update the 'OS/2 ulUnicodeRange*' bits after subsetting. The Unicode
408   ranges defined in the OpenType specification v1.7 are intersected with
409   the Unicode codepoints specified in the font's Unicode 'cmap' subtables:
410   when no overlap is found, the bit will be switched off. However, it will
411   *not* be switched on if an intersection is found. [default]
412 --no-prune-unicode-ranges
413   Don't change the 'OS/2 ulUnicodeRange*' bits.
```

Security Analysis Report

```
414 --prune-codepage-ranges
415     Update the 'OS/2 ulCodePageRange*' bits after subsetting. [default]
416 --no-prune-codepage-ranges
417     Don't change the 'OS/2 ulCodePageRange*' bits.
418 --recalc-average-width
419     Update the 'OS/2 xAvgCharWidth' field after subsetting.
420 --no-recalc-average-width
421     Don't change the 'OS/2 xAvgCharWidth' field. [default]
422 --recalc-max-context
423     Update the 'OS/2 usMaxContext' field after subsetting.
424 --no-recalc-max-context
425     Don't change the 'OS/2 usMaxContext' field. [default]
426 --font-number=<number>
427     Select font number for TrueType Collection (.ttc/.otc), starting from 0.
428 --pretty-svg
429     When subsetting SVG table, use lxml pretty_print=True option to indent
430     the XML output (only recommended for debugging purposes).
431
432 Application options
433 ^^^^^^^^^^^^^^^^^^^^^
434
435 --verbose
436     Display verbose information of the subsetting process.
437 --timing
438     Display detailed timing information of the subsetting process.
439 --xml
440     Display the TTX XML representation of subsetted font.
441
442 Example
443 ^^^^^^^
444
445 Produce a subset containing the characters ' !"#%' without performing
446 size-reducing optimizations::
447
448 $ fonttools subset font.ttf --unicodes="U+0020-0025" \
449   --layout-features=* --glyph-names --symbol-cmap --legacy-cmap \
450   --notdef-glyph --notdef-outline --recommended-glyphs \
451   --name-IDs=* --name-legacy --name-languages=*
452 ""
453 )
454
455
456 log = logging.getLogger("fontTools.subset")
457
458
459 def _log_glyphs(self, glyphs, font=None):
460     self.info("Glyph names: %s", sorted(glyphs))
461     if font:
462         reverseGlyphMap = font.getReverseGlyphMap()
463         self.info("Glyph IDs: %s", sorted(reverseGlyphMap[g] for g in glyphs))
464
465
466 # bind "glyphs" function to 'log' object
467 log.glyphs = MethodType(_log_glyphs, log)
468
469
470 -----
471
472 >> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
```

Security Analysis Report

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/fontTools/ttLib/tables/otBase.py:954:36`

```
953         else:
954             if conv.aux and not eval(conv.aux, None, self.__dict__):
955                 continue
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/fontTools/ttLib/tables/otBase.py:992:40`

```
991         else:
992             if conv.aux and not eval(conv.aux, None, table):
993                 continue
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/fontTools/ttLib/tables/otBase.py:1096:36`

```
1095         else:
1096             if conv.aux and not eval(conv.aux, None, table):
1097                 continue
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/fontTools/ttLib/tables/otBase.py:1138:36`

```
1137         else:
1138             if conv.aux and not eval(conv.aux, None, vars(self)):
1139                 continue
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/fontTools/ttLib/tables/otConverters.py:81:33`

```
80         else:
81             converterClass = eval(spec.type, tableNamespace, converterMapping)
82
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/fontTools/ttLib/tables/otTables.py:1726:36`

```
1725         else:
1726             if conv.aux and not eval(conv.aux, None, vars(self)):
1727                 continue
```

Security Analysis Report

>> Issue: [B324:hashlib] Use of weak SHA1 hash for security. Consider usedforsecurity=False
Severity: High Confidence: High
CWE: CWE-327 (<https://cwe.mitre.org/data/definitions/327.html>)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
Location: `./venv/lib/python3.12/site-packages/fontTools/varLib/interpolatablePlot.py:161:24`

```
160         with open(file, "rb") as f:  
161             h = hashlib.sha1(f.read()).hexdigest()  
162             self.draw_label("sha1: %s" % h, x=x + pad, y=y, width=width)
```

>> Issue: [B305:blacklist] Use of insecure cipher mode cryptography.hazmat.primitives.ciphers.modes.ECB.
Severity: Medium Confidence: High
CWE: CWE-327 (<https://cwe.mitre.org/data/definitions/327.html>)

More

Info:

https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b304-b305-ciphers-and-modes

```
Location: ./venv/lib/python3.12/site-packages/fpdf/encryption.py:535:40  
534     # nosemgrep: python.cryptography.security.insecure-cipher-mode-ecb.insecure-cipher-mode-ecb  
535     cipher = Cipher(AES256(self.k), modes.ECB())  
536     encryptor = cipher.encryptor()
```

>> Issue: [B604:any_other_function_with_shell_equals_true] Function call with shell=True parameter identified, possible security issue.

Severity: Medium Confidence: Low

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More

Info:

https://bandit.readthedocs.io/en/1.9.4/plugins/b604_any_other_function_with_shell_equals_true.html

```
Location: ./venv/lib/python3.12/site-packages/pip/_internal/commands/completion.py:130:18  
129         )  
130         print(BASE_COMPLETION.format(script=script, shell=options.shell))  
131         return SUCCESS
```

>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True identified, security issue.

Severity: High Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html

Location: `./venv/lib/python3.12/site-packages/pip/_internal/commands/configuration.py:247:12`

```
246         try:  
247             subprocess.check_call(f'{editor} "{fname}"', shell=True)  
248         except FileNotFoundError as e:
```

>> Issue: [B411:blacklist] Using xmlrpc.client to parse untrusted XML data is known to be vulnerable to XML attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./venv/lib/python3.12/site-packages/pip/_internal/commands/search.py:7:0`

```
6 import textwrap  
7 import xmlrpc.client  
8 from collections import OrderedDict
```

Security Analysis Report

```
-----
>> Issue: [B411:blacklist] Using xmlrpc.client to parse untrusted XML data is known to be vulnerable to XML
attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML
vulnerabilities.
```

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./venv/lib/python3.12/site-packages/pip/_internal/network/xmlrpc.py:5:0`

```
4 import urllib.parse
5 import xmlrpc.client
6 from typing import TYPE_CHECKING
```

```
-----
>> Issue: [B411:blacklist] Using _HostType to parse untrusted XML data is known to be vulnerable to XML
attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML
vulnerabilities.
```

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./venv/lib/python3.12/site-packages/pip/_internal/network/xmlrpc.py:13:4`

```
12 if TYPE_CHECKING:
13     from xmlrpc.client import _HostType, _Marshallable
14
```

```
-----
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query
construction.
```

Severity: Medium Confidence: Low

CWE: CWE-89 (<https://cwe.mitre.org/data/definitions/89.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html

Location: `./venv/lib/python3.12/site-packages/pip/_internal/utils/pylock.py:282:14`

```
281         raise InstallationError(
282             f"Cannot select requirements from pylock file {pylock_path_or_url!r}: {exc}"
283         ) from exc
```

```
-----
>> Issue: [B202:tarfile_unsafe_members] tarfile.extractall used without any validation. Please check and
discard dangerous members.
```

Severity: High Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b202_tarfile_unsafe_members.html

Location: `./venv/lib/python3.12/site-packages/pip/_internal/utils/unpacking.py:245:12`

```
244
245         tar.extractall(location, filter=pip_filter)
246
```

```
-----
>> Issue: [B411:blacklist] Using xmlrpclib to parse untrusted XML data is known to be vulnerable to XML
attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML
vulnerabilities.
```

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: `./venv/lib/python3.12/site-packages/pip/_vendor/distlib/compat.py:42:4`

```
41     import httpplib
42     import xmlrpclib
43     import Queue as queue
```

Security Analysis Report

>> Issue: [B411:blacklist] Using xmlrpc.client to parse untrusted XML data is known to be vulnerable to XML attacks. Use defusedxml.xmlrpc.monkey_patch() function to monkey-patch xmlrpclib and mitigate XML vulnerabilities.

Severity: High Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b411-import-xmlrpclib

Location: ../venv/lib/python3.12/site-packages/pip/_vendor/distlib/compat.py:81:4

```
80     import urllib.request as urllib2
81     import xmlrpc.client as xmlrpclib
82     import queue
```

>> Issue: [B202:tarfile_unsafe_members] tarfile.extractall used without any validation. Please check and discard dangerous members.

Severity: High Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b202_tarfile_unsafe_members.html

Location: ../venv/lib/python3.12/site-packages/pip/_vendor/distlib/util.py:1285:8

```
1284
1285         archive.extractall(dest_dir)
1286
```

>> Issue: [B102:exec_used] Use of exec detected.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b102_exec_used.html

Location: ../venv/lib/python3.12/site-packages/pip/_vendor/pkg_resources/__init__.py:1714:12

```
1713         code = compile(source, script_filename, 'exec')
1714         exec(code, namespace, namespace)
1715     else:
```

>> Issue: [B102:exec_used] Use of exec detected.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b102_exec_used.html

Location: ../venv/lib/python3.12/site-packages/pip/_vendor/pkg_resources/__init__.py:1725:12

```
1724         script_code = compile(script_text, script_filename, 'exec')
1725         exec(script_code, namespace, namespace)
1726
```

>> Issue: [B108:hardcoded_tmp_directory] Probable insecure usage of temp file/directory.

Severity: Medium Confidence: Medium

CWE: CWE-377 (<https://cwe.mitre.org/data/definitions/377.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b108_hardcoded_tmp_directory.html

Location: ../venv/lib/python3.12/site-packages/pip/_vendor/platformdirs/unix.py:182:29

```
181         if not Path(path).exists():
182             path = f"/tmp/runtime-{getuid()}" # noqa: S108
183     else:
```

>> Issue: [B102:exec_used] Use of exec detected.

Severity: Medium Confidence: High

Security Analysis Report

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b102_exec_used.html

Location: `./venv/lib/python3.12/site-packages/pip/_vendor/pygments/formatters/__init__.py:103:12`

```
102         with open(filename, 'rb') as f:
103             exec(f.read(), custom_namespace)
104         # Retrieve the class `formattername` from that namespace
```

>> Issue: [B102:exec_used] Use of exec detected.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b102_exec_used.html

Location: `./venv/lib/python3.12/site-packages/pip/_vendor/pygments/lexers/__init__.py:154:12`

```
153         with open(filename, 'rb') as f:
154             exec(f.read(), custom_namespace)
155         # Retrieve the class `lexername` from that namespace
```

>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False

Severity: High Confidence: High

CWE: CWE-327 (<https://cwe.mitre.org/data/definitions/327.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html

Location: `./venv/lib/python3.12/site-packages/pip/_vendor/requests/auth.py:148:23`

```
147             x = x.encode("utf-8")
148             return hashlib.md5(x).hexdigest()
149
```

>> Issue: [B324:hashlib] Use of weak SHA1 hash for security. Consider usedforsecurity=False

Severity: High Confidence: High

CWE: CWE-327 (<https://cwe.mitre.org/data/definitions/327.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html

Location: `./venv/lib/python3.12/site-packages/pip/_vendor/requests/auth.py:156:23`

```
155             x = x.encode("utf-8")
156             return hashlib.sha1(x).hexdigest()
157
```

>> Issue: [B324:hashlib] Use of weak SHA1 hash for security. Consider usedforsecurity=False

Severity: High Confidence: High

CWE: CWE-327 (<https://cwe.mitre.org/data/definitions/327.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html

Location: `./venv/lib/python3.12/site-packages/pip/_vendor/requests/auth.py:205:17`

```
204
205         cnonce = hashlib.sha1(s).hexdigest()[:16]
206         if _algorithm == "MD5-SESS":
```

>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.

Severity: Medium Confidence: High

CWE: CWE-502 (<https://cwe.mitre.org/data/definitions/502.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle

Location: `./venv/lib/python3.12/site-packages/pip/_vendor/rich/style.py:471:66`

```
470         """Get meta information (can not be changed after construction)."""
471         return {} if self._meta is None else cast(Dict[str, Any], loads(self._meta))
472
```


Security Analysis Report

>> Issue: [B108:hardcoded_tmp_directory] Probable insecure usage of temp file/directory.

Severity: Medium Confidence: Medium

CWE: CWE-377 (<https://cwe.mitre.org/data/definitions/377.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b108_hardcoded_tmp_directory.html

Location: `./.venv/lib/python3.12/site-packages/platformdirs/unix.py:184:21`

```
183         if sys.platform.startswith("openbsd"):
184             path = f"/tmp/run/user/{getuid()}" # noqa: S108
185         elif sys.platform.startswith(("freebsd", "netbsd")):
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/py_serializable/__init__.py:974:42`

```
973         # Will load any class already loaded assuming fully qualified name
974         self._type_ = eval(f'{mapped_array_type}[{results.get("array_of")}']')
975         self._concrete_type = eval(str(results.get('array_of')))
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/py_serializable/__init__.py:975:50`

```
974         self._type_ = eval(f'{mapped_array_type}[{results.get("array_of")}']')
975         self._concrete_type = eval(str(results.get('array_of')))
976         except NameError:
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/py_serializable/__init__.py:1007:42`

```
1006         # Will load any class already loaded assuming fully qualified name
1007         self._type_ = eval(f'{mapped_array_type}[{results.get("array_of")}']')
1008         self._concrete_type = eval(str(results.get('array_of')))
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer `ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./.venv/lib/python3.12/site-packages/py_serializable/__init__.py:1008:50`

```
1007         self._type_ = eval(f'{mapped_array_type}[{results.get("array_of")}']')
1008         self._concrete_type = eval(str(results.get('array_of')))
1009         except NameError:
```

>> Issue: [B314:blacklist] Using `xml.etree.ElementTree.fromstring` to parse untrusted XML data is known to be vulnerable to XML attacks. Replace `xml.etree.ElementTree.fromstring` with its defusedxml equivalent function or make sure `defusedxml.defuse_stdlib()` is called

Severity: Medium Confidence: High

CWE: CWE-20 (<https://cwe.mitre.org/data/definitions/20.html>)

Security Analysis Report

More

Info:

https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b313-b320-xml-bad-elementtree

Location: `./venv/lib/python3.12/site-packages/pygame/_camera_opencv.py:27:16`

```
26
27     for node in ElementTree.fromstring(flout).iterfind("./array/dict/array/dict/*"):
28         if last_text == "_name":
```

>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.

Severity: Medium Confidence: High

CWE: CWE-502 (<https://cwe.mitre.org/data/definitions/502.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle

Location: `./venv/lib/python3.12/site-packages/pygame/tests/color_test.py:1173:24`

```
1172     pickle_string = pickle.dumps(c1)
1173     c1_frompickle = pickle.loads(pickle_string)
1174     self.assertEqual(c1, c1_frompickle)
```

>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).

Severity: Medium Confidence: High

CWE: CWE-377 (<https://cwe.mitre.org/data/definitions/377.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q

Location: `./venv/lib/python3.12/site-packages/pygame/tests/image_test.py:154:17`

```
153     # third party SDL_image library.
154     f_path = tempfile.mktemp(suffix=".jpg")
155     pygame.image.save(surf, f_path)
```

>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).

Severity: Medium Confidence: High

CWE: CWE-377 (<https://cwe.mitre.org/data/definitions/377.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q

Location: `./venv/lib/python3.12/site-packages/pygame/tests/image_test.py:184:17`

```
183
184     f_path = tempfile.mktemp(suffix=".png")
185     pygame.image.save(surf, f_path)
```

>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).

Severity: Medium Confidence: High

CWE: CWE-377 (<https://cwe.mitre.org/data/definitions/377.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q

Location: `./venv/lib/python3.12/site-packages/pygame/tests/image_test.py:228:17`

```
227
228     f_path = tempfile.mktemp(suffix=".png")
229     pygame.image.save(surf, f_path)
```

>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).

Severity: Medium Confidence: High

CWE: CWE-377 (<https://cwe.mitre.org/data/definitions/377.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q

Location: `./venv/lib/python3.12/site-packages/pygame/tests/image_test.py:264:17`

```
263
264     f_path = tempfile.mktemp(suffix=".png")
265     pygame.image.save(surf, f_path)
```

Security Analysis Report

>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).

Severity: Medium Confidence: High

CWE: CWE-377 (<https://cwe.mitre.org/data/definitions/377.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q

Location: `./venv/lib/python3.12/site-packages/pygame/tests/image_test.py:305:17`

```
304
305     f_path = tempfile.mktemp(suffix=".png")
306     pygame.image.save(surf, f_path)
```

>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.

Severity: Medium Confidence: High

CWE: CWE-502 (<https://cwe.mitre.org/data/definitions/502.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle

Location: `./venv/lib/python3.12/site-packages/pygame/tests/math_test.py:2956:25`

```
2955     v3 = Vector3(1, 2, 3)
2956     self.assertEqual(pickle.loads(pickle.dumps(v2)), v2)
2957     self.assertEqual(pickle.loads(pickle.dumps(v3)), v3)
```

>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.

Severity: Medium Confidence: High

CWE: CWE-502 (<https://cwe.mitre.org/data/definitions/502.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle

Location: `./venv/lib/python3.12/site-packages/pygame/tests/math_test.py:2957:25`

```
2956     self.assertEqual(pickle.loads(pickle.dumps(v2)), v2)
2957     self.assertEqual(pickle.loads(pickle.dumps(v3)), v3)
2958
```

>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider `usedforsecurity=False`

Severity: High Confidence: High

CWE: CWE-327 (<https://cwe.mitre.org/data/definitions/327.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html

Location: `./venv/lib/python3.12/site-packages/pygame/tests/test_utils/png.py:2721:12`

```
2720     x, y, pixel, meta = r.read_flat()
2721     d = hashlib.md5(seqtobytes(pixel)).digest()
2722     self.assertEqual(_enhex(d), "255cd971ab8cd9e7275ff906e5041aa0")
```

>> Issue: [B307:blacklist] Use of possibly insecure function - consider using `safer ast.literal_eval`.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

Location: `./venv/lib/python3.12/site-packages/pygame/tests/test_utils/test_runner.py:245:19`

```
244     try:
245         return eval(test_results.group(1))
246     except:
```

>> Issue: [B102:exec_used] Use of `exec` detected.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

Security Analysis Report

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b102_exec_used.html

Location: `./venv/lib/python3.12/site-packages/pygments/formatters/__init__.py:103:12`

```
102         with open(filename, 'rb') as f:
103             exec(f.read(), custom_namespace)
104         # Retrieve the class `formattername` from that namespace
```

>> Issue: [B102:exec_used] Use of exec detected.

Severity: Medium Confidence: High

CWE: CWE-78 (<https://cwe.mitre.org/data/definitions/78.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b102_exec_used.html

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/__init__.py:154:12`

```
153         with open(filename, 'rb') as f:
154             exec(f.read(), custom_namespace)
155         # Retrieve the class `lexername` from that namespace
```

>> Issue: [B310:blacklist] Audit url open for permitted schemes. Allowing use of file:/ or custom schemes is often unexpected.

Severity: Medium Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b310-urllib-urlopen

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_lua_builtins.py:225:12`

```
224     def get_newest_version():
225         f = urlopen('http://www.lua.org/manual/')
226         r = re.compile(r'^<A HREF="(\\d\\.\\d)/">(Lua )?\1</A>')
```

>> Issue: [B310:blacklist] Audit url open for permitted schemes. Allowing use of file:/ or custom schemes is often unexpected.

Severity: Medium Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b310-urllib-urlopen

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_lua_builtins.py:233:12`

```
232     def get_lua_functions(version):
233         f = urlopen(f'http://www.lua.org/manual/{version}/')
234         r = re.compile(r'^<A HREF="manual.html#pdf-(?!lua|LUA)([^\:]+)">\1</A>')
```

>> Issue: [B310:blacklist] Audit url open for permitted schemes. Allowing use of file:/ or custom schemes is often unexpected.

Severity: Medium Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b310-urllib-urlopen

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_mysql_builtins.py:1297:19`

```
1296         # Pull content from lex.h.
1297         lex_file = urlopen(LEX_URL).read().decode('utf8', errors='ignore')
1298         keywords = parse_lex_keywords(lex_file)
```

>> Issue: [B310:blacklist] Audit url open for permitted schemes. Allowing use of file:/ or custom schemes is often unexpected.

Severity: Medium Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b310-urllib-urlopen

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_mysql_builtins.py:1303:27`

```
1302         # Parse content in item_create.cc.
```

Security Analysis Report

```
1303         item_create_file = urlopen(ITEM_CREATE_URL).read().decode('utf8', errors='ignore')
1304         functions.update(parse_item_create_functions(item_create_file))
```

>> Issue: [B310:blacklist] Audit url open for permitted schemes. Allowing use of file:/ or custom schemes is often unexpected.

Severity: Medium Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b310-urllib-urlopen

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_php_builtins.py:3299:19`

```
3298     def get_php_references():
3299         download = urlretrieve(PHP_MANUAL_URL)
3300         with tarfile.open(download[0]) as tar:
```

>> Issue: [B202:tarfile_unsafe_members] tarfile.extractall used without any validation. Please check and discard dangerous members.

Severity: High Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b202_tarfile_unsafe_members.html

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_php_builtins.py:3304:16`

```
3303         else:
3304             tar.extractall()
3305             yield from glob.glob(f"{PHP_MANUAL_DIR}{PHP_REFERENCE_GLOB}")
```

>> Issue: [B310:blacklist] Audit url open for permitted schemes. Allowing use of file:/ or custom schemes is often unexpected.

Severity: Medium Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b310-urllib-urlopen

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_postgres_builtins.py:642:18`

```
641     def update_myself():
642         content = urlopen(DATATYPES_URL).read().decode('utf-8', errors='ignore')
643         data_file = list(content.splitlines())
```

>> Issue: [B310:blacklist] Audit url open for permitted schemes. Allowing use of file:/ or custom schemes is often unexpected.

Severity: Medium Confidence: High

CWE: CWE-22 (<https://cwe.mitre.org/data/definitions/22.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b310-urllib-urlopen

Location: `./venv/lib/python3.12/site-packages/pygments/lexers/_postgres_builtins.py:647:18`

```
646
647         content = urlopen(KEYWORDS_URL).read().decode('utf-8', errors='ignore')
648         keywords = parse_keywords(content)
```

>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.

Severity: Medium Confidence: High

CWE: CWE-502 (<https://cwe.mitre.org/data/definitions/502.html>)

More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle

Location: `./venv/lib/python3.12/site-packages/rich/style.py:475:66`

```
474         """Get meta information (can not be changed after construction)."""
475         return {} if self._meta is None else cast(Dict[str, Any], loads(self._meta))
476
```

Security Analysis Report

```
-----
>> Issue: [B108:hardcoded_tmp_directory] Probable insecure usage of temp file/directory.
Severity: Medium Confidence: Medium
CWE: CWE-377 (https://cwe.mitre.org/data/definitions/377.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b108\_hardcoded\_tmp\_directory.html
Location: ../.venv/lib/python3.12/site-packages/stevedore/_cache.py:153:39
152         os.path.isfile(os.path.join(self._dir, '.disable')),
153         sys.executable[0:4] == '/tmp', # noqa: S108,
154     ]
```

```
-----
>> Issue: [B108:hardcoded_tmp_directory] Probable insecure usage of temp file/directory.
Severity: Medium Confidence: Medium
CWE: CWE-377 (https://cwe.mitre.org/data/definitions/377.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b108\_hardcoded\_tmp\_directory.html
Location: ../.venv/lib/python3.12/site-packages/stevedore/tests/test_cache.py:28:50
27     """
28     with mock.patch.object(sys, 'executable', '/tmp/fake'):
29         sot = _cache.Cache()
```

```
-----
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
Severity: Medium Confidence: High
CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist\_calls.html#b307-eval
Location: ../.venv/lib/python3.12/site-packages/typing_extensions.py:4034:53
4033         return_value = {key:
4034             value if not isinstance(value, str) else eval(value, globals, locals)
4035             for key, value in ann.items() }
```

```
-----
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
Severity: Medium Confidence: High
CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist\_calls.html#b307-eval
Location: ../.venv/lib/python3.12/site-packages/typing_extensions.py:4116:20
4115         code = forward_ref.__forward_code__
4116         value = eval(code, globals, locals)
4117         forward_ref.__forward_evaluated__ = True
```

Code scanned:

```
Total lines of code: 591513
Total lines skipped (#nosec): 8
Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 23
```

Run metrics:

```
Total issues (by severity):
  Undefined: 0
  Low: 2346
  Medium: 49
  High: 25
Total issues (by confidence):
  Undefined: 0
  Low: 4
```

Security Analysis Report

```
Medium: 173
High: 2243
Files skipped (0):
[main] INFO profile include tests: None
[main] INFO profile exclude tests: None
[main] INFO cli include tests: None
[main] INFO cli exclude tests: None
[main] INFO running on Python 3.12.13
[manager] WARNING Test in comment: _lines is not a test name or id, ignoring
[manager] WARNING Test in comment: is is not a test name or id, ignoring
[manager] WARNING Test in comment: a is not a test name or id, ignoring
[manager] WARNING Test in comment: dict is not a test name or id, ignoring
[manager] WARNING Test in comment: of is not a test name or id, ignoring
[manager] WARNING Test in comment: line is not a test name or id, ignoring
[manager] WARNING Test in comment: number is not a test name or id, ignoring
[manager] WARNING Test in comment: set is not a test name or id, ignoring
[manager] WARNING Test in comment: of is not a test name or id, ignoring
[manager] WARNING Test in comment: tests is not a test name or id, ignoring
[manager] WARNING Test in comment: to is not a test name or id, ignoring
[manager] WARNING Test in comment: ignore is not a test name or id, ignoring
[manager] WARNING Test in comment: tkelsey is not a test name or id, ignoring
[manager] WARNING Test in comment: catching is not a test name or id, ignoring
[manager] WARNING Test in comment: expected is not a test name or id, ignoring
[manager] WARNING Test in comment: exception is not a test name or id, ignoring
[tester] WARNING nsec encountered (B108), but no failed test on file
./venv/lib/python3.12/site-packages/bandit/plugins/general_hardcoded_tmp.py:61
[manager] WARNING Test in comment: c is not a test name or id, ignoring
[manager] WARNING Test in comment: B410 is not a test name or id, ignoring
[manager] WARNING Test in comment: B320 is not a test name or id, ignoring
[manager] WARNING Test in comment: we is not a test name or id, ignoring
[manager] WARNING Test in comment: use is not a test name or id, ignoring
[manager] WARNING Test in comment: a is not a test name or id, ignoring
[manager] WARNING Test in comment: custom is not a test name or id, ignoring
[manager] WARNING Test in comment: prepared is not a test name or id, ignoring
[manager] WARNING Test in comment: safe is not a test name or id, ignoring
[manager] WARNING Test in comment: parser is not a test name or id, ignoring
[tester] WARNING nsec encountered (B324), but no failed test on file
./venv/lib/python3.12/site-packages/fpdf/fpdf.py:5888
[tester] WARNING nsec encountered (B324), but no failed test on file
./venv/lib/python3.12/site-packages/fpdf/image_parsing.py:157
[tester] WARNING nsec encountered (B324), but no failed test on file
./venv/lib/python3.12/site-packages/fpdf/image_parsing.py:163
```

2. Dependency Audit - pip-audit

No known vulnerabilities found

3. Network Traffic Analysis

```
$ ss -tp
(no python network connections found)
```

```
$ lsof -i -n -P
(no python network connections found)
```

4. Manual Penetration Testing Checks

Security Analysis Report

SQL Injection

PASS - core/game.py uses parameterized queries (?) with no string-formatted SQL detected.

Hardcoded Secrets

WARN:

```
security_report.py:75: # 2. Hardcoded secrets
security_report.py:76: secret_hits = []
security_report.py:88: k in low for k in ("password", "secret", "api_key", "token")
security_report.py:91: secret_hits.append(f"{rel}:{i}: {line.strip()}")
security_report.py:92: checks["Hardcoded Secrets"] = (
security_report.py:93: "PASS - No suspicious secret keywords found."
security_report.py:94: if not secret_hits
security_report.py:95: else "WARN:\n" + "\n".join(secret_hits)
```

Path Traversal

INFO - resource_loader.py does not use open() directly.

Save File Tampering

INFO - No save files present. No tampering risk currently.